BridgeWitness

Real-time detection of cross-chain bridge exploits that **decides** on proof, not on guesses: every release must consume a real, unspent deposit, to the wei.

An independent monitor and enforcement point for cross-chain bridges. It replays bridge feeds, flags mismatched deposit/withdrawal pairs, volume spikes and unusual signer behaviour, and raises a risk-scored alert that names the suspected exploit and carries evidence anyone can re-run in a browser.

382/382 real Nomad exploit releases flagged, from the first one	**0/4,482** matched Nomad transfers flagged	**6/6** simulated attack scenarios typed correctly; 2/2 controls raise no exploit alert	**12/12** reference evidence bundles re-verified in the browser

Nomad labels come from XChainWatcher's own matching rules; the simulated replay is synthetic by design. See §8.

Bridges are the biggest target, and exploits outrun humans

> **CSB-01 (Chainalysis):** cross-chain bridges move billions between blockchains and are the single largest source of crypto hacks. Exploits (fake deposits, signature forgery, liquidity draining) often complete within minutes, faster than manual monitoring can react. Expected: a dashboard over a live or replayed feed that flags volume spikes, unusual signer behaviour and mismatched deposit/withdrawal pairs, and raises a risk-scored alert with the suspected exploit type.

Why it is hard

Bridge attacks differ in mechanism but share one effect: the destination chain releases tokens that the source chain never locked. Three common defences each miss it, and we measured two of them on real data:

Defence	Why it fails	Measured on the real datasets
Signature / quorum checks	Stolen keys make valid signatures	Ronin: 5 of 9 validator keys were stolen (public reports); the signatures were valid
Volume-spike detection	Fires late, or not at all, and false-alarms on busy honest periods	Ronin: **0 of 2** releases flagged. Nomad: first flag at **+2,986 s**, by which time **17 releases and $23.6M (14.8%)** had already gone; 3.1% false alarms on normal Nomad traffic
Large-transfer ("whale") alerts	Fire only after funds moved	Ronin: both releases exceed $1M, but post-execution response recovers at most ~4.5%

The scale

- Chainalysis estimated roughly **$2B stolen from bridges in 2022** (public estimate; motivation, not our result).
- **Ronin** (23 Mar 2022): two withdrawals **115 s apart**; ~$624M public estimate ($565.4M at dataset prices).
- **Nomad** (1 Aug 2022): **382 releases in 167 transactions** by **279 recipients**, 9 tokens, **$159.6M** dataset USD, over ~2.5 hours. Copycats reused only 14 distinct message ids (id 4922 appears 279 times).

Who feels it

Bridge operators and their security teams; exchanges and custodians that rely on bridged assets; compliance, forensics and analytics firms; auditors and insurers. (Intended users from our analysis; not yet validated through interviews.)

02 · SOLUTION

Check the one thing every exploit has in common

BridgeWitness is the CSB-01 dashboard first. It ingests a bridge transaction feed (a replayed public dataset, a simulated attack replay, or a live local chain), runs three detectors on every release, and raises one risk-scored alert that names the suspected exploit and shows its reasons.

The three signals the brief asks for

Signal	In plain words	Role
Mismatched deposit/withdrawal pairs Conservation Ledger	A bridge is a vault with two doors: money may leave the far door only if the same amount, for the same person, came in through the near door. We check that for every release, in exact 256-bit integers.	Decides: may trigger a hold
Volume spikes Velocity detector	A smoke alarm for bursts of releases on one route (5-minute count, 5-minute vs 1-hour rate, volume vs the 24-hour median). Threshold fixed on pre-attack data only.	Advises: ranks, never holds
Unusual signer behaviour Signer forensics	Unknown or too few signers, duplicates; the same signer set co-signing a burst; valid signatures on a release nobody paid for (the Ronin pattern).	Rules decide; behaviour advises

The alert

Every alert carries a **risk score 0–100 with its arithmetic shown** and a **suspected exploit type**: fake deposit, signature forgery, validator-key compromise, unbacked release, message replay, mismatched pair, liquidity drain (incident level), or an advisory volume/signer anomaly. The score is `clamp(base(type) + min(15, 3·log10 USD) + campaign ≤ 5) × evidence completeness`: a ranking, not a probability.

Beyond detection: what we add

- **Hold before funds move** (pre-execution gate) with scope that widens only as evidence demands.
- **Evidence that anyone can re-run**: each verdict ships as a bundle your browser re-verifies.
- **Honesty about blind spots**: missing data yields `unknown`, never a false alarm.

Three demo feeds, one engine

Feed	What it shows	Data
Simulated attack replay	The brief's demo: fake deposit, signature forgery, replay, stolen-key liquidity drain, two mismatched pairs, plus two controls that must not raise an exploit alert	`SYNTHETIC · SEED 2410`
Nomad and Ronin replays	The 2022 exploits on a virtual clock; Nomad's 382 alerts collapse into one incident	`REAL · XCHAINWATCHER`
Live local chains	A compromised validator signs a release with no deposit; the gate holds it while a healthy route settles exactly 25 units	`REFERENCE RUN · LOCAL ONLY`

What changes for the people defending a bridge

Earlier, mechanism-independent detection

The backing check does not care *how* the attacker got in: stolen keys, a verification bug or a fake deposit all produce a release with no matching deposit. On the Nomad replay it flags the first release (+0 s); the volume detector needed +2,986 s.

Fewer, better alerts

382 Nomad violations become **one incident** with live USD exposure and a copycat signal, instead of 382 pages. Missing data becomes `unknown`, not a false accusation. Advisory signals cannot hold funds.

A smaller blast radius

The counterfactual replays Nomad under response policies. At 0 s latency, holding the attacked routes limits loss to **13.2%**, adaptive scope to **7.0%**, and freezing the whole bridge to **5.8%**. At 15 minutes, holding routes alone fails (**65.8%**), which is why scope must escalate to the shared verifier. We show our narrow policy losing where it should.

Trust you can check

Operators, auditors and regulators do not have to believe our alert. They re-run it: header hash, Merkle proofs, accounting rule and SHA-256, all in the browser. Change one wei and verification fails.

Counterfactual loss, Nomad (share of dataset USD lost)

Response latency	Pause whole bridge	Hold attacked routes	Adaptive scope
0 s	5.8%	13.2%	7.0%
60 s	10.1%	17.7%	11.5%
15 min	10.4%	65.8%	33.8%

> **Read this carefully.** These are estimates under a replay model: attackers are assumed to behave the same after a hold, and detection is assumed to fire on the first unbacked release. USD is the dataset's historical value, not a live price. They are **not** funds recovered, and we do not claim "funds saved".

Who benefits, and how (intended)

- **Bridge security teams:** an independent second opinion that cannot be silenced by the bridge's own trust set, with a hold they control.
- **Exchanges and custodians:** an early, explainable signal on the bridged assets they accept.
- **Analytics, forensics and compliance:** evidence bundles that can be handed to a third party and independently reproduced.
- **Auditors and insurers:** a standard, checkable record of what was released against what was deposited.

04 · KEY FEATURES

What the prototype does today

Feature	What you can do	Status
Monitor dashboard	Pick a feed, play at 1–300×, seek on an event-density scrubber; three signal panels, alert queue, incidents, transaction stream with explorer links	WORKING
Risk-scored alerts	Score breakdown, suspected exploit type, every reason shown; "hold-eligible" vs "advisory" is explicit	WORKING
Conservation Ledger playground	Edit a release (one wei too many, replay, wrong recipient, 20-part salami) and watch the real rule respond	WORKING
Cross-chain flow graph (3D)	575 releases as edges between Moonbeam message commitments and Ethereum beneficiaries by token; a "no deposit" node; fan-out ranking (id 4922 → 279 releases); inspector	WORKING · NOMAD DATA
Evidence library and verifier	12 bundles; collapsible tree with violating fields marked; in-browser verification; tamper mode with diff	WORKING
Counterfactual theatre	Five response policies, log latency slider (0 s to 6 days), Nomad/Ronin toggle, loss vs containment breadth	WORKING
Witness bridge (3D)	Towers, threads and gates; all six verdict states; alert takeover on the first violation	WORKING
Watermarks and unknown	Per-chain observation cursor; "Blind the source RPC" turns new releases into unknown, not alarms	PREVIEW CONSTANTS
Incident correlation	Nomad: one incident, 382 violations, 279 recipients, scope escalating to the verifier at +2,986 s	PREVIEW CONFIG
Attack tests (12 attacks)	Each attack runs through the real rule in the browser on a simulated bridge and is compared with its expected verdict; attack #1 also shows the real local-chain result; "Run all 12" scores them	DEMO · LIVE-CHAIN LAUNCH PENDING
USP demos page	One interactive demo per USP: proof of non-deposit, evidence re-check, unknown-vs-false-alarm, hold-before-execution gate, what-if responses, incident grouping, self-attack test	DEMO · TAGGED REAL VS SIMULATED
Eval and model card	The three signals measured on the datasets; advisory ML card; engine latency	WORKING · baselines PENDING
Docs	Evidence spec (schema, verdicts, hashing, procedure, trust boundary) and architecture	WORKING

Prototype status: frontend only, running in fixture mode. 14 pages. No backend, live stream or database yet. Demos run in the browser on simulated data and are labelled as such.

05 · UNIQUE SELLING POINTS

Seven capabilities on top of the brief, each with a working demo

The backing invariant itself is established prior art (XChainWatcher, Count of Monte Crypto, Wormhole's Global Accountant) and we cite it. What follows is our engineering combination, honestly labelled by maturity: **real** (works on real data) or **demo** (works in your browser on simulated data).

#	USP	In plain words	Maturity
01	**Proof of Non-Deposit**	Not "our indexer saw nothing": a Merkle proof from the source chain's own state that the deposit slot is empty	DEMO · SIMULATED BRIDGE
02	**Re-executable evidence**	Every alert is a file your browser re-checks, down to one trusted block header; one changed wei fails	WORKING · 12/12
03	**Watermarked verdicts**	"Rule broken" and "cannot see yet" are different answers; RPC lag never produces a false exploit alert	DEMO · SIMULATED FEED
04	**Pre-execution gate, adaptive scope**	Releases wait in a short window; a violation is held before funds move; the hold widens message → route → shared verifier only when evidence demands	DEMO · ROUTE HOLD ALSO PROVEN ON LOCAL CHAINS
05	**Counterfactual response analysis**	Replays a real exploit under five response policies and shows the loss for each	WORKING
06	**Incident correlation**	Hundreds of violations become one incident with live exposure and a copycat signal	PREVIEW
07	**Adversarial self-evaluation**	We attack our own monitor (congestion, RPC gaps, a lying indexer) and compare against whale-alert and z-score baselines	DEMO · 12 OF 12 MATCH

Design principles behind them

1. **Invariants decide; ML advises.** Only a deterministic rule violation can trigger containment. The ML model (recall 2.34%, 9 of 384 held-out; ROC AUC 0.982 on its raw score) is advisory only and not used for decisions.
2. **Every verdict carries its evidence.**
3. **Blind spots are named:** missing data means `unknown`, never "attack" and never "fine".
4. **Smallest sufficient intervention**, recorded with its evidence hash.
5. **No inflated claims.** A priority is a ranking; AUC is not accuracy; USD has a stated source.

Built on working parts, with the gaps stated

Technical feasibility: what already works

- **Reference engine (Python):** exact accounting, SQLite WAL ledger with idempotent ingest and reorg rebuild, Merkle-Patricia receipt/transaction proofs, finalized contiguous scanner; **55 tests passing**.
- **Live demonstration (local):** two Ganache chains; a compromised-validator release held before execution; a healthy route settling exactly 25 units; 0 public-chain transactions.
- **Performance (local, measured):** p50 **0.82 ms**, p99 **2.6 ms** per deposit + release pair (SQLite FULL commit, excludes HTTP/RPC; hardware-specific).
- **Frontend:** React, three.js, TypeScript; the in-browser verifier matches Python on all 12 reference bundles; every number comes from a script that fails on drift.
- **Data:** public, MIT-licensed XChainWatcher datasets, pinned by SHA-256.

What remains to build (and the plan)

Gap	Plan	Risk
Backend API and live stream	Port the TS detectors to Python; FastAPI with SSE; single-writer engine	Low: reference engine and API already exist
Proof of Non-Deposit in bundles	Productise the verified spike (`eth_getProof`, exclusion proof) and add the bundle field	Medium: works for bridges that store deposits in state; others fall back to watermark mode, stated in the bundle
Optimistic gate and verifier-wide hold	Extend the demo contracts (`holdWithEvidence`, `resolve`)	Medium: needs contract changes; contracts are unaudited demos
Evaluation and baselines	Seeded fault injector (S0–S7), baselines B1–B3, ablation, one results file	Low
Public-network adapter	Testnet first (Sepolia / Base Sepolia), then production bridge formats	Higher: per-bridge adapters and RPC coverage; finality is an RPC assumption

Operational viability

- **Light footprint:** consumes finalized blocks and receipts over standard RPC; one writer process; millisecond-scale decisions.
- **Independent of the bridge's trust set:** it reads public chain data, so it can be deployed by an operator, a third-party monitor or an analytics firm.
- **Safe by construction:** volume and ML signals can rank but never hold; holds are scoped, evidence-linked and need an explicit resolution to lift.

Business viability (proposed, not yet validated)

- **Possible models:** monitoring-as-a-service per bridge route; an enterprise integration for analytics and compliance platforms (the evidence bundle is the product); open-source verifier with a paid hosted monitor.
- **Why it could hold:** checkable evidence is hard to copy by assertion; an open bundle format creates trust and adoption; the hold feature serves operators' response needs.
- **Not done:** customer interviews, pricing or revenue modelling. We make no market-size claims.

> **Key risks.** (1) The backing check needs complete source-chain coverage; with gaps it says unknown by design. (2) Finality is an RPC assumption until a light client anchors it. (3) Each production bridge needs its own adapter; liquidity and intent bridges are out of the current route model. (4) Attackers may adapt after a hold. (5) Public datasets lack signer data, so signer signals are demonstrated on simulated and local-chain data.

07 · WHAT MAKES US STAND OUT

Five things, each backed by something you can run

#	Differentiator	Proof in the prototype
1	**It answers the brief fully, then goes further.** All three requested signals, risk-scored alerts with the suspected exploit type, a replayed public dataset and a simulated attack replay.	Monitor page; requirement checklist in the PRD (§A) and on the landing page
2	**It measures the alternatives, honestly.** We show where volume detection is late (+2,986 s, $23.6M gone on Nomad) or silent (0/2 on Ronin), instead of assuming it works.	Eval page; fixture assertions
3	**Alerts that prove themselves.** The judge's browser re-runs the verdict; tampering one wei is caught and shown as a diff.	Evidence page and USP demo 02; 12/12 golden bundles
4	**It enforces, not just alerts.** A release with no deposit is held before execution on the local chains, while a healthy route keeps settling; scope is chosen by evidence and measured on Nomad.	Attack tests (#1 and the gate demo); What-if page
5	**It is honest by construction.** unknown instead of false alarms, ML kept advisory, non-claims on every page, synthetic and pending items labelled, numbers generated by code.	Footer non-claims; PROGRESS.md claims register

How this differs from existing approaches (from public material; not an audit of their internals)

Approach	Where it stops	What we add
Validator quorum / multisig	Stolen keys sign validly	Backing check independent of signatures
Rate limits and volume rules	Late, or defeated by splitting the theft	Exact accounting; volume only advises
Research reconciliation (XChainWatcher, Monte Crypto)	Offline or alert-only	Live replay, pre-execution hold, browser-verifiable evidence
Commercial monitors	Closed evidence that cannot be independently checked	Re-executable bundles with an explicit trust boundary
Protocol-native conservation (e.g. Wormhole Global Accountant)	Works only inside its own ecosystem	An independent witness across bridges

> **Positioning.** We do not claim to predict hacks. We refuse to execute what has no backing, and we show the proof. We position this as an engineering combination validated by adversarial testing, not as a new academic result.

What is real, what is synthetic, what is not built

Measured results

Finding	Result	Source
Backing rule on Nomad exploit releases	382 / 382, from +0 s	TS port over dataset rows
Backing rule on matched Nomad transfers	0 / 4,482 flagged	same
Backing rule on Ronin exploit releases	2 / 2	same
Volume detector on Nomad	first flag +2,986 s; 314 / 382 eventually	velocity port
Loss before first volume flag (Nomad)	$23,591,072 (14.8%)	dataset USD
Volume detector on Ronin	0 / 2	velocity port
Volume false alarms, normal traffic	3.1% Nomad · 1.5% Ronin	velocity port
Simulated replay: attacks typed correctly	6 / 6; 2 / 2 controls: no exploit alert	fixture assertions
Simulated replay: advisory volume false alarms	6 / 101 background	velocity port
Browser verifier equals Python	12 / 12 bundles	golden test
Engine latency (local)	p50 0.82 ms · p99 2.6 ms	reference benchmark
ML model (advisory)	recall 2.34% (9/384) · FPR 0.44% · AUC 0.982	reference evaluation

Synthetic or preview in the prototype

- **Simulated attack replay:** 130 releases (101 background, 19 attack, 10 control); background resampled from real Ronin transfers; validators and signatures fabricated.
- **Signer signals:** simulated feed and local chains only; Nomad/Ronin data has no signers.
- **Nomad/Ronin verdicts:** computed by our TypeScript port of the rule, not yet by the backend.
- **Observer lag, SLA, incident window, copycat thresholds:** placeholder constants.
- **Live bridge results:** one reference run on local, unaudited demo chains.
- **USP demos and the 12 attacks:** simulated bridge, invented deposits and addresses; the checking rule and the proof mechanics are real. Reorg handling, the early-release rule and the overdue timer are a thin engine layer, labelled on screen.

Not built yet

- Backend API, live stream, database
- Proof of Non-Deposit from a real chain (demo uses a simulated one)
- On-chain optimistic gate and verifier-wide hold; launching attacks on real chains
- Scenarios S0–S7, baselines B1–B3, ablation
- Public-testnet adapter, light-client finality

> **Circularity, stated openly.** Nomad's attack labels come from XChainWatcher's own matching rules, so reproducing them shows our implementation is correct, not independent detection power. Planned mitigations: a clean-room matcher diffed against the paper's unmatched-withdrawals file, injected scenarios, and the XScope incident catalog.

Data and licence. Nomad and Ronin CSVs: XChainWatcher (Augusto et al., arXiv 2410.02029), © 2024 André Augusto, MIT License, commit 4cc1ff1, pinned by SHA-256. USD values are the dataset's historical `value_usd`. The demo runs on local chains with unaudited contracts; no public-network funds are involved. Words we do not use: "100% accurate", "AI-powered", "funds saved".